VULNSCAN — Automated Security Intelligence

Security Assessment & Vulnerability Audit Report

Generated on 2026-10-30 21:07:22 UTC | Platform: VulnScan v1.0

Target Project:	Live Target Audit	**Security Score:**	**83 / 100**
Target Scope:	https://designsphere-one.vercel.app/	**Scan Mode:**	COMPREHENSIVE
Scan ID:	#6	**Gate Status:**	**PASS**

1. Executive Summary

VulnScan completed a multi-vector security assessment across static source code (SAST), runtime endpoints (DAST), software dependencies (SCA), and credential exposure checks. The audit identified **4 total finding(s)** across the target scope. Immediate attention is recommended for Critical and High severity findings prior to production deployment.

CRITICAL	HIGH	MEDIUM	LOW	INFO	FIXED
0	**0**	**3**	**1**	**0**	**0**

2. Detailed Vulnerability Findings

#1 Missing Content-Security-Policy (CSP) Header — MEDIUM

Category:	Security Misconfiguration	**CWE / CVE:**	CWE-1021
Location:	https://designsphere-one.vercel.app:	**Source:**	DAST

Technical Evidence:

```
HTTP Status: 200, Headers present: Access-Control-Allow-Origin, Age, Cache-Control, Content-Disposition, Content-Encoding
```

Technical Explanation: Content-Security-Policy restricts resources (such as scripts, images, stylesheets) that the browser is allowed to load for a given page.

Remediation: Implement a strict Content-Security-Policy header (e.g. default-src 'self').

#2 Missing X-Frame-Options (Clickjacking Risk) — MEDIUM

Category:	Security Misconfiguration	**CWE / CVE:**	CWE-1021
Location:	https://designsphere-one.vercel.app:	**Source:**	DAST

Technical Evidence:

```
X-Frame-Options header not found in server response.
```

Technical Explanation: Attackers can render the application within a transparent frame on a malicious page to trick users into triggering unintended actions.

Remediation: Add 'X-Frame-Options: DENY' or 'SAMEORIGIN' to all HTTP responses.

#3 Missing X-Content-Type-Options Header			LOW
Category:	Security Misconfiguration	**CWE / CVE:**	CWE-16
Location:	https://designsphere-one.vercel.app:	**Source:**	DAST

Technical Evidence:

```
Header X-Content-Type-Options missing
```

Technical Explanation: If a browser interprets a non-executable file as executable script, it can lead to script execution vulnerabilities.

Remediation: Send 'X-Content-Type-Options: nosniff' header.

#4 Overly Permissive Cross-Origin Resource Sharing (CORS: *)			MEDIUM
Category:	Security Misconfiguration	**CWE / CVE:**	CWE-942
Location:	https://designsphere-one.vercel.app:	**Source:**	DAST

Technical Evidence:

```
Access-Control-Allow-Origin: *
```

Technical Explanation: Untrusted origins can read authenticated data if credentials or sensitive tokens are exposed.

Remediation: Restrict allowed origins to trusted domains.

---

3. DevSecOps Deployment Gate & Next Steps

Deployment Policy Enforcement:

• Critical and High severity findings must be resolved and verified before staging deployment.
• Use VulnScan's AI Security Assistant to review contextual code patches.
• Execute Fix Verification Rescan to mark resolved items and unblock the CI/CD pipeline.